PUBLIC
SAP HANA Remote Data Sync 2.0 SP 03
Document Version: 1.0 – 2019-04-05

SAP HANA Remote Data Sync: Security Guide

© 2019 SAP SE or an SAP affiliate company. All rights reserved.

THE BEST RUN SAP

Content

1 SAP HANA Remote Data Sync: Security Guide. 3

2 Remote Data Sync Security Considerations. 4

2.1 Remote Data Sync System Landscape. 4

2.2 User Administration and Authentication. 6

User Name and Password Authentication. 6

Authentication Parameters. 6

2.3 Securing SAP HANA Remote Data Sync in the Consolidated Database. 7

2.4 Security-Related Remote Data Sync Startup Options. 7

2.5 Multiple Synchronization Applications With the Same Remote Data Sync Server. 7

3 Remote Data Sync Server Logging. 9

3.1 View the Remote Data Sync Server Log. 10

4 Data Flow Security. 11

4.1 Transport Layer Security. 11

5 Remote Data Sync Client/Server Communications Encryption. 13

5.1 End-to-End Encryption. 13

5.2 Start the Remote Data Sync Server with Transport Layer Security. 13

5.3 Remote Data Sync Client Configuration to Use Transport Layer Security. 14

Server Authentication. 14

Client Security Options. 16

Transport Layer Security over TCP/IP and HTTPS. 16

1 SAP HANA Remote Data Sync: Security Guide

This guide provides an overview of the security-relevant information that applies to SAP HANA remote data sync.

2 Remote Data Sync Security Considerations

There are several aspects to securing data throughout a widely distributed system such as a remote data sync installation.

Protecting data in the consolidated database

Data in the consolidated database can be protected using the database user authentication system and other security features.

For more information, see Securing Remote Data Synchronization In The Consolidated Database [page 7].

Protecting data in the remote databases

If you are using SAP SQL Anywhere remote databases, the data can be protected by using SAP SQL Anywhere security features. By default, these features are designed to prevent unauthorized access through client/server communications, but the default is not fully secure and may not prevent a serious attempt to extract information directly from the database file.

Protecting data on the synchronization client device

Files on the synchronization client device are protected by the security features of the device operating system.

Protecting data during synchronization

Communication from remote data sync clients to remote data sync servers can be protected by the remote data sync transport layer security features.

Protecting the synchronization system from unauthorized users

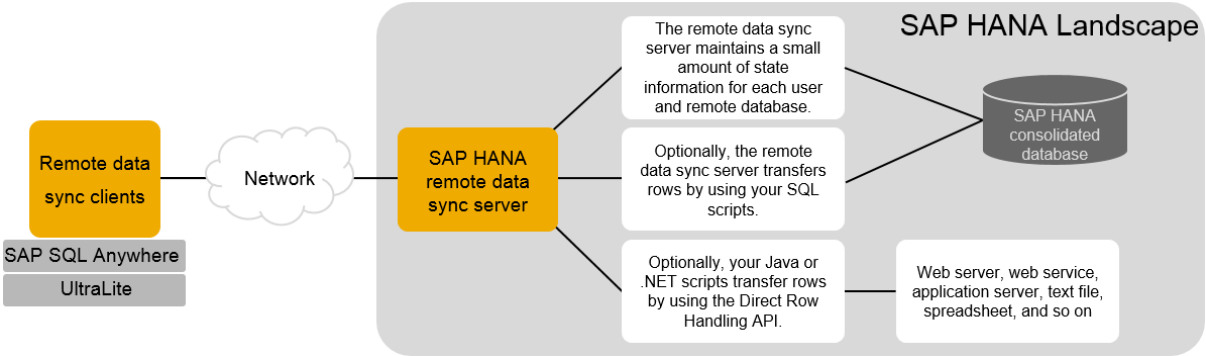
SAP HANA remote data sync can be secured by a password-based user authentication system. This mechanism prevents unauthorized users from synchronizing data.

Protecting data from users with unnecessary privileges

Through the granting and revoking of roles and privileges, you can ensure that users have the correct authority to perform synchronizations, without having more authority than is desirable.

2.1 Remote Data Sync System Landscape

In SAP HANA remote data sync, many clients synchronize through the remote data sync server to central data sources.



Remote data sync clients

The client can be installed on a mobile device, a server or desktop computer, or a smart phone. Two types of clients are supported: UltraLite and SAP SQL Anywhere databases. Either or both can be used in a remote data sync installation. Both SAP SQL Anywhere and UltraLite must be purchased separately and are components of the SAP SQL Anywhere product.

Network

The connection between the remote data sync server and the remote data sync client can use the TCP/IP or HTTP protocols. See:

- Remote data sync server: protocol Configuration Option and protocol_options Configuration Option option
- UltraLite and SAP SQL Anywhere clients: remote data sync client network protocol options

Remote data sync server

This server manages the synchronization process and provides the interface between all remote data sync clients and the consolidated database server.

Consolidated database

This SAP HANA database typically contains the central copy of your application information in the synchronization system. It also holds system tables and procedures that are required by remote data synchronization, and state information needed to synchronize.

State information

The remote data sync server maintains synchronization information in system tables in the consolidated database, in the SAP_HANA_SYNC catalog.

SQL row handling

If you provide the remote data sync server with SQL scripts, it uses these scripts to transfer rows to and from the SAP HANA consolidated database.

Direct row handling

In addition to a consolidated database, you can optionally synchronize with other data sources using remote data sync direct row handling via Java.

Synchronization scripts

You write synchronization scripts for each table in the remote database and you save these scripts in remote data sync system tables in the consolidated database. These scripts determine how authentication takes place, what is done with the uploaded data, and what data to download.

2.2 User Administration and Authentication

A **remote data sync user**, also called a **synchronization user**, is the name you use to authenticate when you connect to the remote data sync server.

For a user to be part of a synchronization system:

- A remote data sync user name must be created on the remote database.
- The remote data sync user name must be registered with the remote data sync server.

Remote data sync user names and passwords are not the same as database user names and passwords. Remote data sync user names authenticate the connection from the remote database to the remote data sync server. The authentication happens via authentication scripts that are invoked during synchronization. A database user with the **sap.hana.sync.monitor.roles::administrator** role creates the authentication scripts. Authentication scripts can reference existing enterprise authentication mechanisms like LDAP.

You need the **sap.hana.sync.monitor.roles::administrator** role to execute stored procedures such as ml_add_table_script and ml_add_connection_script.

2.2.1 User Name and Password Authentication

The default method of user authentication for SAP HANA remote data sync is to use a white listed set of user names and passwords that is stored in the SAP_HANA_SYNC schema.

Add approved user names and passwords by using the mluser command-line tool that is part of SAP SQL Anywhere . The following command adds a remote data sync user with user name user1 and password pwd1 to the HANA data source. The UID and PWD values in the command line must belong to an SAP HANA database user with permissions to modify tables in the SAP_HANA_SYNC schema. The cs=SAP_HANA_SYNC connection parameter is required.

```
mluser -c "DSN=MY_HANA_DSN;UID=SYSTEM;PWD=manager;CS=SAP_HANA_SYNC" -u user1 -p
pwd1
```

The mluser utility can also read user names and passwords from a file. For more information, refer to the SAP SQL Anywhere documentation.

2.2.2 Authentication Parameters

In remote data sync scripts, specify authentication parameters with named parameters.

Preface the authentication parameters with the letter a, such as {ml a.1}. The parameters must be numbers starting at 1, with a limit of 255. Each parameter can be a maximum of 4000 bytes. The values are sent up from remote data sync clients.

When used in the authenticate_* scripts, authentication parameters pass authentication information.

On SAP SQL Anywhere remotes, you pass the information with the dbmlsync -ap option. On UltraLite remotes, you pass the information with auth_parms and num_auth_parms.

2.3 Securing SAP HANA Remote Data Sync in the Consolidated Database

When a remote database synchronizes, the remote data sync server connects to the HANA consolidated database as the SYS_SYNC user and invokes the synchronization scripts associated with the script version sent up from the remote database.

The SYS_SYNC user does not have a password and the synchronization server connects over an encrypted connection by using a certificate-based assertion ticket mechanism for security.

The SYS_SYNC user must be granted the appropriate privileges on all tables referenced in the remote data sync scripts, and EXECUTE privileges on any procedures referenced in the remote data sync scripts.

The synchronization scripts themselves should only be modified by approved users who are granted the **sap.hana.sync.monitor.roles::administrator** role.

2.4 Security-Related Remote Data Sync Startup Options

Use remote data sync startup options to help secure your synchronization environment.

The protocol and protocol_options configuration options set network protocol options that are used by the remote data sync server to listen for synchronization requests. Set the protocol option to tls or https for secure communications between the synchronization clients and the synchronization server.

Consider using end-to-end (e2ee) encryption if the synchronization requests are decrypted at any point between the synchronization client and the synchronization server. This decryption by an intermediary can happen, for example, if the load balancer serving the synchronization server farm decrypts, then re-encrypts the synchronization traffic.

2.5 Multiple Synchronization Applications With the Same Remote Data Sync Server

Considerations for setting up multiple synchronization applications that use the same remote data sync server.

The remote data sync server connects as the pre-defined user SYS_SYNC. The SYS_SYNC user has sufficient privileges to connect to and manipulate the remote data sync system tables.

For a single application, remote data sync scripts are grouped into a named script version. There may be multiple script versions in use by the same remote data sync server

You must grant the SYS_SYNC user the appropriate privileges on all tables referenced by the remote data sync scripts, and EXECUTE privileges on any procedures referenced by the remote data sync scripts. Repeat this task for each sync script version that is supported by the same remote data sync server.

When you need to support synchronization for multiple applications, then choose one of the following deployment options:

- Use the same remote data sync server for all of the applications. The SYS_SYNC user is shared between the applications. This can result in a lot of object-level privileges and roles being assigned to this one user. For example, suppose your organization has a sales application and a shipping application that synchronize to the same SAP HANA database instance. The SYS_SYNC user for the database must be granted the roles and/or privileges to execute the synchronization scripts for both applications.
- Use a separate remote data sync server for each application. This option requires an independent SAP HANA database instance (tenant) for each remote data sync server.

3 Remote Data Sync Server Logging

Logging the actions that the server takes is particularly useful during the development process and when troubleshooting. Verbose output is not recommended for normal operation of a production environment because it can slow performance.

The remote data sync server logs its output to the following location:

```
/usr/sap/XY1/HDBXX/hostname/trace/rdsyncserver_hostname.3XX27.NNN.trc
```

Where:

- XY1 is the SID of your HANA system
- XX is the instance number of your HANA system
- `<hostname>` is the host name of a host running the **rdsync** role in your HANA landscape
- NNN is a number between 000 and 999

Controlling the amount of logging output

The `rdsyncserver.ini` file contains some settings that affect the amount of logging output due to SAP HANA remote data sync, under the [trace] section:

- maxfiles controls the maximum number of log files.
- maxfilesize controls the size of each log file.
- The remote data sync server controls the trace level. Specify one of (in order of increasing verbosity): FATAL, ERROR, WARNING, INFO, or DEBUG.

Each time the current log file reaches maxfilesize, a new log file is created with (NNN+1) as the number. If the number of files exceeds maxfiles, then the oldest log file is removed.

Controlling which warning messages are reported

You can control which warning messages are reported using the -zw, -zwd, and -zwe options, specifying them in the extra_options section of the remote data sync configuration.

3.1 View the Remote Data Sync Server Log

Use HANA Studio to view remote data sync logs.

Procedure

1. On the **Systems** tab, right-click any running HANA system remote data synchronization servers.
2. Choose **Configuration and Monitoring** > **Open Administration** >.
3. Choose the **Diagnosis Files** tab.
4. Browse to the host and log file (`rdsyncserver_*.trc`) and double-click it to open it for viewing.

4 Data Flow Security

Restrict access to synchronization scripts and use transport layer security to secure the data flow in SAP HANA remote data sync.

Synchronization scripts

When a remote database synchronizes, the remote data synchronization server connects to the HANA consolidated database and invokes the synchronization scripts associated with the script version sent up from the remote database.

The SYS_SYNC user must be granted the appropriate privileges on all tables referenced in the remote data sync scripts, and EXECUTE privileges on any procedures referenced in the remote data sync scripts.

The synchronization scripts themselves should only be modified by approved users who are granted the **sap.hana.sync.monitor.roles::administrator** role.

End-to-end encryption

End-to-end encryption occurs when data is encrypted at the point of origin and decrypted at the final destination. Use transport layer security to secure communications between the remote data sync server and clients.

Starting the remote data sync server with transport layer or HTTPS security To start the remote data sync server with transport layer security, supply the identity file and the identity password protecting the server's private key.

Remote data sync client configuration to use transport layer security You can configure SAP SQL Anywhere clients to use remote data sync transport layer security.

4.1 Transport Layer Security

Transport Layer Security (TLS), an IETF standard protocol, secures client/server communications by using digital certificates and public-key cryptography.

Transport layer security enables encryption, tamper detection, and certificate-based authentication.

Secure communication begins with an exchange of messages (a handshake) including **server authentication**.

Transport layer security uses server certificates to establish and maintain a secure connection. You create unique certificate files for each server or obtain them from a certificate authority.

- For remote data synchronization, a remote data sync client (SAP SQL Anywhere or UltraLite) verifies the identity of a remote data sync server.

Efficiency

The transport layer security protocol uses a combination of public-key and symmetric-key encryption. Public-key encryption provides better authentication techniques, but is computationally intensive. Once a secure connection is established, the client and server use a highly efficient symmetric cipher with 128-bit key size for the rest of their communication.

Certificates

Use the SAP SQL Anywhere Certificate Creation Utility (createcert) to create X.509 certificate files for transport layer security. However, if you need to verify the existence of third-party certificates, or if you need more secure certificates, then you can purchase the certificates from certificate authorities.

5 Remote Data Sync Client/Server Communications Encryption

You can encrypt remote data sync client/server communication using transport layer security.

5.1 End-to-End Encryption

End-to-end encryption occurs when data is encrypted at the point of origin and decrypted at the final destination, without being decrypted in between.

There is no point during transmission that the data is unencrypted.

In SAP HANA remote data sync, transport layer security (TLS) is sometimes only used to encrypt data up to an intermediary (for example, encryption/decryption hardware) between the client and server. At the intermediary, the data would be decrypted and then encrypted again by the intermediary for the rest of the journey. Notably, this happens when synchronizing via HTTPS through a Web server. The brief interval when the data is unencrypted in the intermediary is sometimes called the Wireless Application Protocol gap or WAP Gap.

Within a corporation, a WAP gap is often acceptable when the intermediary is within corporate control. However, in a third-party hosted environment where data from different corporations is going through the same WAP gap, sensitive data may be exposed. End-to-end encryption prevents any intermediary from accessing the data because the synchronization stream is encrypted from start to finish, and may optionally be encrypted once more with TLS.

See the e2ee_* settings in the protocol_options configuration option of the remote data sync server.

5.2 Start the Remote Data Sync Server with Transport Layer Security

Start the remote data sync server with transport layer security by supplying the identity file and the identity password that protect the server's private key.

Procedure

1. Use the protocol_options configuration option to specify an identity and an identity password. The configuration for specifying secure communications options is:

```
protocol={tls | https}
```

```
protocol_options=identity=<identity-file>;identity_password=<password>;…
```

2. Set the options as follows:

   protocol

   The protocol to use. It can be *https* or *tls*. The *tls* protocol indicates the use of TCP/IP with Transport Layer Security.

   identity-file

   The path and file name of the identity file, which contains the server's private key, the server's certificate, and, optionally, the certificates signed by the Certificate Authority.

   password

   The password for the server private key. You specify this password when you create the server identity.

Results

You have started the remote data sync server with transport layer security.

> **Example**
>
> The following example specifies transport layer security, the server identity file, and the identity password protecting the server's private key.
>
> ```
> protocol=tls
> protocol_options=identity=rsaserver.id;identity_password=test
> ```

5.3 Remote Data Sync Client Configuration to Use Transport Layer Security

You can configure SAP SQL Anywhere or UltraLite clients to use remote data sync transport layer security.

For each client, you specify trusted certificates, the type of encryption, and the network protocol.

5.3.1 Server Authentication

Server authentication allows a remote client to verify the identity of a remote data sync server.

Digital signatures and certificate field verification work together to achieve server authentication.

Digital signatures

A remote data sync server certificate contains one or more digital signatures used to maintain data integrity and protect against tampering. Following are the steps used to create a digital signature:

- An algorithm performed on a certificate generates a unique value or hash.
- The hash is encrypted using a signing certificate's or Certificate Authority's private key.
- The encrypted hash, called a digital signature, is embedded in the certificate.

A digital signature can be self-signed or signed by an enterprise root certificate or Certificate Authority.

When a remote data sync client contacts a remote data sync server, and each is configured to use transport layer security, the server sends the client a copy of its certificate. The client decrypts the certificate's digital signature using the server's public key included in the certificate, calculates a new hash of the certificate, and compares the two values. If the values match, this confirms the integrity of the server's certificate.

Verifying certificate fields

When using a globally signed certificate, each client must verify certificate field values to avoid trusting certificates that the same Certificate Authority has signed for other clients. This is resolved by requiring your clients to test the value of fields in the identity portion of the certificate. A Certificate Authority must guarantee the accuracy of the identification information in any certificate that it signs.

When creating a certificate using the createcert utility, you enter values for the organization, organizational unit, and common name fields. You verify these fields using corresponding remote data sync client connection parameters.

Organization

The organization field corresponds to the certificate_company remote data sync client connection parameter.

Organizational unit

The organizational unit field corresponds to the certificate_unit remote data sync client connection parameter.

Common name

The common name field corresponds to the certificate_name remote data sync client connection parameter.

5.3.2 Client Security Options

Remote data sync clients (SAP SQL Anywhere and UltraLite) use a common set of connection parameters to configure transport layer security.

trusted_certificates protocol option

Remote data sync clients use the trusted_certificates protocol option to specify trusted remote data sync server certificates. The trusted certificate can be a server's self-signed certificate, a public enterprise root certificate, or the certificate belonging to a commercial Certificate Authority.

Verifying certificate fields

The certificate_company, certificate_unit, and certificate_name protocol options are used to verify certificate fields, an important step for server authentication. It is strongly recommended that you verify certificate fields if you are using a third-party Certificate Authority to globally sign certificates.

5.3.3 Transport Layer Security over TCP/IP and HTTPS

Remote data sync transport layer security is an inherent feature of the remote data sync HTTPS and TCP/IP protocols.

To use transport layer security over HTTPS, specify the TRUSTED_CERTIFICATES connection parameter using the ADR extended option.

For TLS and HTTPS synchronizations, if none of the certificate_name, certificate_company, or certificate_unit protocol options are provided, remote data sync clients check the host name against the certificate provided by the server. If the Subject Alternative Name extension is present, the client checks the host name against each of the names in the extension. Otherwise, the client checks the host name against the Common Name in the subject field. If no matches are found, the synchronization fails with STREAM_ERROR_SECURE_CERTIFICATE_NOT_TRUSTED. This check supports wildcard matching.

If any of the certificate_name, certificate_company, or certificate_unit protocol options are provided, these values are used to check against the server certificate's subject field, and the host name will be ignored. If the skip_certificate_name_check protocol option is set to "true", no name checking will be done on the server's certificate.

Example

The following example specifies RSA security over HTTPS. In this example, the client checks that any names on the server's certificate match the host name "myserver". The synchronization fails if the host name does not match. Write the command on one line:

```
dbmlsync -c "server=rem1;uid=DBA;pwd=mypwd"
  -e "ctp=https;
```

```
      adr='host=MyServer;
      trusted_certificates=c:\certs\rootca.crt'"
```

Alternatively, you can specify the CommunicationAddress extended option using the CREATE SYNCHRONIZATION SUBSCRIPTION or ALTER SYNCHRONIZATION SUBSCRIPTION statement. This method provides the same information, but stores it in the database.

```
CREATE SYNCHRONIZATION SUBSCRIPTION
 TO pub1
 FOR user1
 ADDRESS 'host=MyServer;
      trusted_certificates=c:\certs\rootca.crt';
```

In the following example, the host name matching is overridden with a direct check of three of the subject fields of the server's certificate. Write the command on one line:

```
dbmlsync -c "server=rem1;uid=<myuid>;pwd=<mypwd>"
   -e "ctp=https;
       adr='host=myserver;
           trusted_certificates=c:\certs\rootca.crt;
           certificate_company=My Company;
           certificate_unit=My Division;
           certificate_name=My RDSync Server'"
```

Important Disclaimers and Legal Information

Hyperlinks

Some links are classified by an icon and/or a mouseover text. These links provide additional information.
About the icons:

- Links with the icon : You are entering a Web site that is not hosted by SAP. By using such links, you agree (unless expressly stated otherwise in your agreements with SAP) to this:
  - The content of the linked-to site is not SAP documentation. You may not infer any product claims against SAP based on this information.
  - SAP does not agree or disagree with the content on the linked-to site, nor does SAP warrant the availability and correctness. SAP shall not be liable for any damages caused by the use of such content unless damages have been caused by SAP's gross negligence or willful misconduct.
- Links with the icon : You are leaving the documentation for that particular SAP product or service and are entering a SAP-hosted Web site. By using such links, you agree that (unless expressly stated otherwise in your agreements with SAP) you may not infer any product claims against SAP based on this information.

Beta and Other Experimental Features

Experimental features are not part of the officially delivered scope that SAP guarantees for future releases. This means that experimental features may be changed by SAP at any time for any reason without notice. Experimental features are not for productive use. You may not demonstrate, test, examine, evaluate or otherwise use the experimental features in a live operating environment or with data that has not been sufficiently backed up.
The purpose of experimental features is to get feedback early on, allowing customers and partners to influence the future product accordingly. By providing your feedback (e.g. in the SAP Community), you accept that intellectual property rights of the contributions or derivative works shall remain the exclusive property of SAP.

Example Code

Any software coding and/or code snippets are examples. They are not for productive use. The example code is only intended to better explain and visualize the syntax and phrasing rules. SAP does not warrant the correctness and completeness of the example code. SAP shall not be liable for errors or damages caused by the use of example code unless damages have been caused by SAP's gross negligence or willful misconduct.

Gender-Related Language

We try not to use gender-specific word forms and formulations. As appropriate for context and readability, SAP may use masculine word forms to refer to all genders.

www.sap.com/contactsap

© 2019 SAP SE or an SAP affiliate company. All rights reserved.

No part of this publication may be reproduced or transmitted in any form or for any purpose without the express permission of SAP SE or an SAP affiliate company. The information contained herein may be changed without prior notice.

Some software products marketed by SAP SE and its distributors contain proprietary software components of other software vendors. National product specifications may vary.

These materials are provided by SAP SE or an SAP affiliate company for informational purposes only, without representation or warranty of any kind, and SAP or its affiliated companies shall not be liable for errors or omissions with respect to the materials. The only warranties for SAP or SAP affiliate company products and services are those that are set forth in the express warranty statements accompanying such products and services, if any. Nothing herein should be construed as constituting an additional warranty.

SAP and other SAP products and services mentioned herein as well as their respective logos are trademarks or registered trademarks of SAP SE (or an SAP affiliate company) in Germany and other countries. All other product and service names mentioned are the trademarks of their respective companies.

Please see https://www.sap.com/about/legal/trademark.html for additional trademark information and notices.

THE BEST RUN SAP